

无线通信安全融合预测终版：按章节版

结合旧版大题预测 + 新预测 PDF + 往年题风格

开卷考试答题向整理

2026 年 6 月 23 日

目录

使用说明	3
1 第 2 讲：密码学基础与认证协议	3
2-1 [A, 10 分] 重放攻击有哪些应对策略？至少说明三种。	3
2-2 [A, 20 分] AES-CBC 中 IV 与密文级联传输，通信密钥提前通过安全信道交换。 请评价并给出建议。	3
2-3 [B, 10 分] 为什么“只加密”不能替代认证和完整性？	4
2 第 3 讲：无线通信威胁与安全体系	4
3-1 [A, 10 分] 安全域是什么？接入认证和 PIN 码认证是否属于同一安全域？	4
3-2 [C, 10 分] 无线通信威胁如何分类？	5
3-3 [B, 10 分] 用安全体系分析伪基站攻击。	5
3 第 4 讲：WLAN 安全	5
4-1 [A, 10 分] WEP 的功能原理和安全性缺陷。	5
4-2 [B, 10 分] 802.1X/EAP 和四次握手分别解决什么问题？	6
4-3 [B, 10 分] WPA2 CCMP 为什么比 WEP 强？	6
4-4 [B, 10 分] WPA3/SAE 相比 WPA2-PSK 解决了什么问题？	6
4 第 5 讲：GSM 安全	7
5-1 [B, 10 分] 描述 GSM 用户鉴权流程，并分析缺陷。	7
5-2 [B, 10 分] TMSI 匿名是否足够？为什么 GSM 容易受到伪基站攻击？	7
5-3 [B, 10 分] GSM 中 Fn 的作用是什么？为什么需要重新鉴权或更新密钥？	7
5 第 6 讲：TETRA 安全	8
6-1 [A, 10 分] TETRA 空口加密和端到端加密的密钥流同步区别。	8
6-2 [B, 10 分] 为什么端到端加密不能替代空口加密？	8
6-3 [B, 10 分] 比较 GSM 空口加密、TETRA 空口加密和 TETRA 端到端加密。	8

6 第 7 讲: WCDMA 安全	9
7-1 [A, 10/15 分] 说明 WCDMA AKA 流程、安全目标, 以及相比 GSM 的增强。	9
7-2 [A, 10 分] WCDMA 中为什么每换一个基站或安全上下文时要重新认证/重新建立安全?	9
7-3 [B, 10 分] f8 和 f9 的区别是什么?	9
7 第 8 讲: LTE 安全	10
8-1 [A, 15 分] LTE 密钥管理能否实现前向安全和后向安全?	10
8-2 [B, 10 分] LTE 为什么要把 NAS 安全和 AS 安全分开?	10
8-3 [B, 10 分] 说明 LTE 安全连接建立过程。	10
8-4 [B, 10 分] LTE 有哪些典型攻击面?	10
8-5 [B, 10 分] 为什么 5G 要引入用户面完整性保护?	11
8 第 12 讲: 5G 网络安全	11
12-1 [A, 15 分] 5G 匿名的新方法是什么? 分析优缺点。	11
12-2 [B, 10 分] 5G-AKA 相比 LTE AKA 有哪些增强?	12
12-3 [B, 10 分] 说明 SEPP 的作用。	12
12-4 [B, 10 分] 5G 切片安全要解决什么问题? 为什么需要二次认证?	12
12-5 [B, 10 分] 5G SBA 服务化核心网需要解决哪些安全问题?	12
9 第 10 讲: 课程总结与未来安全	13
10-1 [C, 10 分] 为什么 5G 不是简单加强空口加密?	13
10-2 [C, 10 分] 未来移动网络安全研究热点有哪些?	13
10-3 [A, 综合比较] 比较 GSM、WCDMA、LTE、5G 在认证、完整性、身份隐私和密钥管理上的演进。	13
10-4 [A, 20 分综合设计] 设计一个无线接入安全方案, 要求保护永久身份、双向认证、协商会话密钥, 并保护后续信令和用户数据。	13
综合分析题专项模板	14
模板 1 [A, 通用分析] 某方案只加密用户面数据, 不做完整性校验, 也不检查序列号。请分析缺陷并改进。	14
模板 2 [A, 身份隐私] 某无线接入方案要求终端使用永久身份明文接入网络。请分析问题并改进。	15
模板 3 [A, 认证缺陷] 某方案只有网络认证用户, 没有用户认证网络。请分析缺陷并改进。	15
模板 4 [A, 密钥管理] 某方案长期使用同一通信密钥, 且不同方向、不同业务共用同一密钥。请分析缺陷并改进。	15
模板 5 [A, 切换安全] 切换过程中, 源基站直接把旧密钥交给目标基站使用。请分析对前向安全和后向安全的影响。	16
最后十分钟速记	16

使用说明

本版按章节排列，方便开卷考试快速翻。每道题前的 A/B/C 表示优先级：A 为必背主押，B 为高概率补充，C 为保底扩展。复习时间很紧时，先看每章 A 题，再看 B 题。

章节	高概率题型
第 2 讲	重放、只加密不够、AES-CBC 方案分析。
第 3 讲	安全域/PIN、无线威胁分类。
第 4 讲	WEP、802.1X/EAP、四次握手、WPA3/SAE。
第 5 讲	GSM 鉴权、TMSI、伪基站。
第 6 讲	TETRA 空口加密、端到端加密、同步差异。
第 7 讲	WCDMA AKA、AUTN、CK/IK、f8/f9、相比 GSM 增强。
第 8 讲	LTE NAS/AS、eNB 风险、密钥层次、前向/后向安全、安全连接。
第 12 讲	5G SUPI/SUCI、5G-AKA、UP 完整性、SEPP、切片安全。
总结	5G 不是简单加强空口加密、未来移动网络安全。

1 第 2 讲：密码学基础与认证协议

2-1 [A, 10 分] 重放攻击有哪些应对策略？至少说明三种。

考试答案要点：

重放攻击是攻击者截获一次合法消息后，在之后重新发送旧消息，使接收方误认为它是新的合法消息。核心问题是缺少新鲜性检查。

1. 随机数挑战-应答：一方发送 RAND/nonce，另一方把随机数参与 MAC、签名或响应计算。每次随机数不同，旧响应不能通过新挑战。
2. 序列号/计数器：消息带 SQN、COUNT、Seq 等单调变化参数，接收方维护最大值或重放窗口，拒绝重复和过旧消息。
3. 时间戳/有效期：消息带时间戳或过期时间，接收方检查是否在允许窗口内。
4. 完整性绑定：随机数、序列号、时间戳必须纳入 MAC/签名/认证加密，否则攻击者可篡改这些字段。

必写关键词：RAND；nonce；SQN；COUNT；时间戳；重放窗口；MAC 保护；新鲜性。

2-2 [A, 20 分] AES-CBC 中 IV 与密文级联传输，通信密钥提前通过安全信道交换。请评价并给出建议。

考试答案要点：

该方案有一定基础：AES 是标准分组密码；CBC 比 ECB 更好；密钥提前通过安全信道交换，避免密钥在开放无线信道中明文传输。但是它仍不是完整安全通信方案。

主要问题：

1. CBC 只提供机密性，不能提供完整性、来源认证和防重放。
2. CBC 的 IV 应随机、不可预测且同一密钥下不重复。IV 可明文传输，但必须被完整性保护。
3. 攻击者可修改 IV 或密文块，使解密明文发生可控变化；无 MAC 时接收方可能发现不了。
4. 若无 Seq/COUNT/nonce，攻击者可重放旧的 $IV \parallel C$ 。
5. 预共享密钥若长期直接加密大量数据，泄露影响历史和未来通信。
6. CBC 若对填充错误、MAC 错误返回不同提示，可能产生 padding oracle。

改进建议：优先使用 AES-GCM/AES-CCM 等认证加密；若保留 CBC，采用 Encrypt-then-MAC，对身份、方向、算法、序列号、IV、密文整体计算 HMAC/CMAC；加入 Seq/COUNT/nonce，接收端维护重放窗口；用 KDF 派生 K_{enc} 、 K_{mac} 并区分方向和用途；定期更新密钥，统一错误提示。

必写关键词：CBC 只保密；IV 随机不可预测；MAC；认证加密；序列号；KDF；先验 MAC 再解密。

2-3 [B, 10 分] 为什么“只加密”不能替代认证和完整性？

考试答案要点：

加密主要保证机密性，让攻击者看不懂内容；但它不能自动保证消息来自谁、是否被篡改、是否为旧消息重放。攻击者即使看不懂密文，也可能修改 IV、翻转密文比特、替换密文块、删除消息、插入旧消息。接收方若只解密不验证 MAC/签名，就无法发现这些攻击。

完整安全应同时包含：实体认证防冒充，MAC/签名防篡改，随机数/序列号/时间戳防重放，KDF 做密钥分离。工程上优先使用 AES-GCM/CCM 等认证加密，或采用加密后 MAC。

必写关键词：机密性不等于完整性；MAC；来源认证；新鲜性；认证加密。

2 第3讲：无线通信威胁与安全体系

3-1 [A, 10 分] 安全域是什么？接入认证和 PIN 码认证是否属于同一安全域？

考试答案要点：

安全域是具有相近安全需求和安全边界的一组实体。移动通信常见安全域包括接入域、网络域、用户域、应用域。

1. 接入域：保护 UE 接入移动网络，包括用户认证、网络认证、密钥协商、空口加密、完整性、身份隐私。
2. 网络域：保护运营商网元之间通信，如核心网信令保护、漫游边界保护、SEPP。
3. 用户域：保护用户、SIM/USIM、终端之间的本地安全，如 PIN、PUK、终端访问控制。

4. 应用域：保护应用层业务，如 HTTPS、支付、端到端业务加密。

接入认证和 PIN 码认证不属于同一安全域。接入认证属于接入域，解决 UE 是否能接入网络、网络是否真实、双方如何建立会话密钥。PIN 属于用户域，解决当前用户是否有权使用 SIM/USIM。二者都叫认证，但保护对象、参与实体和安全边界不同。

必写关键词：接入域；用户域；认证对象不同；安全边界不同。

3-2 [C, 10 分] 无线通信威胁如何分类？

考试答案要点：

可按攻击对象分为三类：对传递信息的威胁、对用户的威胁、对通信系统的威胁。对信息的威胁包括侦听、篡改、插入、删除、重放、抵赖；对用户的威胁包括身份冒充、IMSI/SUPI 暴露、位置跟踪、流量分析；对系统的威胁包括干扰、拒绝服务、伪基站、资源越权访问、核心网攻击。无线通信中特别突出的是空口窃听、伪基站、身份捕获、无线干扰和移动切换中的密钥风险。

必写关键词：窃听；篡改；重放；伪基站；位置跟踪；拒绝服务。

3-3 [B, 10 分] 用安全体系分析伪基站攻击。

考试答案要点：

伪基站攻击是攻击者搭建假基站，诱导 UE 接入，从而获取用户身份、跟踪位置、降级加密、篡改信令或造成拒绝服务。可按安全体系分析：

1. **接入域问题：**若只有网络认证用户、UE 不认证网络，就会被假基站冒充。GSM 单向认证是典型原因。
2. **身份隐私问题：**伪基站可请求 IMSI/SUPI，导致永久身份暴露和位置跟踪。
3. **完整性问题：**如果控制信令缺少完整性保护，攻击者可篡改算法协商、重定向、寻呼或去附着消息。
4. **降级和可用性问题：**攻击者可诱导 UE 回落到弱制式、关闭加密或制造拒绝服务。

改进方向：采用双向认证，让 UE 验证网络；使用 TMSI/GUTI/SUCI 隐藏永久身份；对控制信令做完整性保护；防止降级，统一错误处理并检测异常基站。

必写关键词：伪基站；单向认证；IMSI/SUPI 捕获；完整性；降级；双向认证。

3 第 4 讲：WLAN 安全

4-1 [A, 10 分] WEP 的功能原理和安全性缺陷。

考试答案要点：

WEP 是早期 WLAN 安全机制，目标是提供类似有线网络的保密性。发送方将共享 WEP Key 与 24 bit IV 输入 RC4 生成密钥流，对明文和 ICV 异或得到密文；ICV 通常由 CRC-32 生成。

缺陷: 24 bit IV 太短, 高流量下容易重复; RC4 是流密码, 密钥流一旦复用, 会泄露明文关系; 静态共享密钥难管理, 一人泄露影响全网; CRC-32/ICV 不是带密钥 MAC, 不能防恶意篡改; 共享密钥认证可能泄露明文和密文关系; 防重放和动态密钥更新能力弱。

改进: WPA2/802.11i 使用 802.1X/EAP 或 PSK 认证, 四次握手派生 PTK/GTK, AES-CCMP 同时提供加密、完整性和防重放。

必写关键词: RC4; 24 bit IV; CRC-32 不是 MAC; 静态共享密钥; 密钥流复用; AES-CCMP。

4-2 [B, 10 分] 802.1X/EAP 和四次握手分别解决什么问题?

考试答案要点:

802.1X/EAP 负责接入认证, 参与方通常是 STA、AP 和认证服务器 AS。STA 通过 AP 与 AS 完成 EAP 认证, 证明用户或设备身份, 认证成功后得到主密钥材料。

四次握手发生在 STA 和 AP 之间, 作用是确认双方都掌握 PMK, 通过 ANonce、SNonce 派生 PTK, 安全分发 GTK, 并用 MIC 验证握手消息完整性。四次握手还保证密钥新鲜性, 避免长期静态密钥。

必写关键词: 802.1X/EAP 认证; ANonce/SNonce; PMK; PTK; GTK; MIC。

4-3 [B, 10 分] WPA2 CCMP 为什么比 WEP 强?

考试答案要点:

WEP 使用 RC4、24 bit IV、静态共享密钥和 CRC-32/ICV, 存在 IV 重复、密钥流复用、CRC 不是 MAC、缺少动态密钥管理等问题。WPA2/802.11i 的 CCMP 基于 AES, 采用类似 CTR 加密和 CBC-MAC 完整性保护的组合, 同时提供机密性、完整性和防重放。WPA2 还通过 802.1X/EAP 或 PSK 认证, 并用四次握手派生 PTK/GTK, 避免长期直接使用静态 WEP Key。总结: WPA2 CCMP 强在强算法、动态密钥、完整性认证和计数器防重放。

必写关键词: AES-CCMP; CTR; CBC-MAC; PTK/GTK; 完整性; 防重放。

4-4 [B, 10 分] WPA3/SAE 相比 WPA2-PSK 解决了什么问题?

考试答案要点:

WPA2-PSK 中, 攻击者可抓取四次握手报文后离线猜测口令; 如果口令弱, 就可能被字典攻击破解。WPA3 使用 SAE, 同样基于口令, 但通过抗离线字典攻击的密钥协商方式, 使攻击者不能仅凭抓包无限离线验证口令。SAE 还提供前向安全: 即使将来口令泄露, 过去会话密钥也不应被直接恢复。总结: WPA3/SAE 主要增强口令认证安全, 缓解离线字典攻击, 并提升前向安全。

必写关键词: PSK; 离线字典攻击; SAE; 前向安全。

4 第 5 讲: GSM 安全

5-1 [B, 10 分] 描述 GSM 用户鉴权流程, 并分析缺陷。

考试答案要点:

SIM 与 AuC 共享长期密钥 K_i 。网络发送 RAND, SIM 用 A3 算法计算 SRES, 用 A8 算法生成 K_c 。网络比较 SRES 与期望值, 若一致则认证用户; 之后用 A5、 K_c 和帧号 Fn 生成密钥流, 对空口进行加密。

缺陷: GSM 只有网络认证用户, UE 不能认证网络, 容易被伪基站攻击; 缺少完整性保护; IMSI 在首次接入或 TMSI 失效时可能明文暴露; A5/COMP128 等早期算法存在弱点; 空口加密不等于端到端安全。

必写关键词: K_i ; RAND; SRES; A3/A8/A5; K_c ; Fn; 单向认证; 无完整性。

5-2 [B, 10 分] TMSI 匿名是否足够? 为什么 GSM 容易受到伪基站攻击?

考试答案要点:

TMSI 是临时身份, 用来减少 IMSI 在空口暴露。正常情况下, 网络尽量用 TMSI 识别用户。但 TMSI 不等于永久匿名: 首次接入、TMSI 失效、网络无法解析 TMSI 时, UE 仍可能明文发送 IMSI。

GSM 容易受伪基站攻击的根本原因是单向认证。网络认证用户, 但手机不认证网络。伪基站可冒充合法网络请求 IMSI, 诱导降级、关闭加密或使用弱加密, 并跟踪用户位置。因此 TMSI 只能降低暴露概率, 不能从根本上解决 IMSI catcher。

必写关键词: TMSI; IMSI; 单向认证; 伪基站; IMSI catcher。

5-3 [B, 10 分] GSM 中 Fn 的作用是什么? 为什么需要重新鉴权或更新密钥?

考试答案要点:

Fn 是 GSM 帧号, 参与 A5 空口加密中的密钥流生成。A5 使用会话密钥 K_c 和帧号 Fn 产生密钥流, 再与明文异或。Fn 的作用是让不同帧使用不同密钥流输入, 避免在同一 K_c 下简单重复密钥流。

但 Fn 不能代替重新鉴权或密钥更新。若长期使用同一 K_c , 密钥泄露后影响范围大; 如果密钥流或算法存在弱点, 长期使用会增加分析风险; 用户移动、重新接入或安全上下文变化时, 也需要确认身份和密钥新鲜性。因此系统需要通过重新鉴权、位置更新、周期性密钥刷新等方式限制旧密钥使用时间。

必写关键词: Fn; A5; K_c ; 密钥流; 密钥新鲜; 重新鉴权。

5 第 6 讲: TETRA 安全

6-1 [A, 10 分] TETRA 空口加密和端到端加密的密钥流同步区别。

考试答案要点:

空口加密保护 MS 到基站/SwMI 的无线链路, 加密终结在网络接入侧; 端到端加密保护最终终端之间的业务内容, 中间网络只转发密文。

空口加密同步对象是 MS 与 SwMI/基站, 依赖空口帧号、时隙、IV、广播同步信息等, 使两端 KSG 生成相同密钥流。课件关键词包括 SCK、DCK、CCK: Class 1 不使用空口加密, Class 2 使用 SCK, Class 3 使用 DCK/CCK。

端到端加密同步对象是两个最终终端, 中间网络不应掌握端到端密钥。它通常通过同步帧、SV、Key ID、端到端计数等信息, 让接收终端知道使用哪把端到端密钥和哪个同步值。总结: 空口同步是“终端-网络”的链路同步, 端到端同步是“终端-终端”的业务密钥流同步。

必写关键词: MS; SwMI; KSG; SCK/DCK/CCK; SV; Key ID; 保护范围不同。

6-2 [B, 10 分] 为什么端到端加密不能替代空口加密?

考试答案要点:

端到端加密保护终端之间的业务内容, 中间网络看不到明文; 但它不一定保护所有空口控制信令、链路管理信息、呼叫控制和无线资源控制信息。空口攻击者仍可能监听或操纵无线链路上的控制信息。

空口加密保护 MS 与 SwMI/基站之间的无线链路, 包括控制和业务在空口段的保护; 端到端加密保护最终业务内容, 防止中间网络或传输链路泄露明文。二者安全边界不同, 是互补关系, 不是替代关系。

必写关键词: 空口控制信令; 业务内容; 链路级保护; 端到端保护; 互补。

6-3 [B, 10 分] 比较 GSM 空口加密、TETRA 空口加密和 TETRA 端到端加密。

考试答案要点:

GSM 空口加密保护 MS 与基站系统之间的无线链路, 使用 K_c 、Fn 和 A5 生成密钥流, 主要防空口窃听, 但网络侧可以解密, 且 GSM 缺少完整性保护。TETRA 空口加密同样是链路级保护, 保护 MS 到 SwMI/基站的无线链路, 可使用 SCK、DCK、CCK 等密钥和 KSG 密钥流生成器, 面向专网、组呼和调度业务。TETRA 端到端加密是业务级保护, 终端到终端加密, 中间 SwMI/网络只转发密文, 不能看到业务明文。

总结: GSM 空口加密和 TETRA 空口加密都保护无线链路; TETRA 端到端加密保护最终业务内容。空口加密防空口监听, 端到端加密防网络内部或传输链路泄露, 二者保护范围不同。

必写关键词: GSM; A5; Fn; TETRA; SCK/DCK/CCK; KSG; 端到端。

6 第 7 讲: WCDMA 安全

7-1 [A, 10/15 分] 说明 WCDMA AKA 流程、安全目标, 以及相比 GSM 的增强。

考试答案要点:

WCDMA AKA 由 USIM 与归属网共享长期密钥 K 。归属网生成认证向量:

$$AV = (RAND, XRES, CK, IK, AUTN).$$

服务网将 RAND 和 AUTN 发给 UE。UE 用 USIM 中的 K 验证 AUTN 中的 MAC 和 SQN: MAC 正确说明认证令牌来自合法归属网, SQN 合理说明不是旧消息重放。UE 计算 RES、CK、IK 并返回 RES; 网络比较 RES 与 XRES, 完成对用户认证。CK 用于加密, IK 用于完整性。

安全目标: 双向认证、密钥协商、密钥新鲜性、防重放、信令完整性、空口机密性。相比 GSM: GSM 是单向认证, 主要生成 K_c , 缺少完整性; WCDMA 使用 AKA 双向认证, CK/IK 分离, 增加信令完整性, 并增强网络域安全。

必写关键词: AV; RAND; XRES; AUTN; SQN; MAC; CK/IK; 双向认证; 信令完整性。

7-2 [A, 10 分] WCDMA 中为什么每换一个基站或安全上下文时要重新认证/重新建立安全?

考试答案要点:

严格说, WCDMA 中并不是每换一个基站都一定完整重新 AKA。更稳妥的说法是: 切换或安全上下文变化时, 需要确认目标接入点合法、安全上下文有效、CK/IK 等密钥材料新鲜, 并保证加密和完整性保护连续。

若上下文能安全转移且仍有效, 可不完整重新 AKA; 若跨域切换、上下文失效、密钥过期、策略要求或上下文无法可信转移, 则需要重新认证或重新建立安全上下文。目的包括防伪基站、防重放、防旧密钥长期复用、防上下文泄露影响后续通信。

必写关键词: 不要绝对写每次完整 AKA; 安全上下文; CK/IK; 合法网络; 密钥新鲜。

7-3 [B, 10 分] f8 和 f9 的区别是什么?

考试答案要点:

WCDMA 中 f8 是机密性算法, 用 CK 生成加密密钥流, 对空口数据进行加密, 主要防窃听。f9 是完整性算法, 用 IK 对信令消息计算 MAC-I, 主要防篡改、伪造和重放。二者对应 CK/IK 密钥分离思想: CK 用于加密, IK 用于完整性。考试可总结为: f8 解决“别人看不懂”, f9 解决“别人改不了/伪造不了”。

必写关键词: f8; f9; CK; IK; 加密; 完整性; MAC-I。

7 第 8 讲: LTE 安全

8-1 [A, 15 分] LTE 密钥管理能否实现前向安全和后向安全?

考试答案要点:

LTE 采用分层密钥体系:

$$K \rightarrow CK/IK \rightarrow K_{ASME} \rightarrow K_{NAS}, K_{eNB} \rightarrow K_{RRC}, K_{UP}.$$

NAS 安全保护 UE 与 MME 之间的核心网控制信令; AS 安全保护 UE 与 eNB 之间的 RRC 信令和用户面。eNB 数量多、部署分散、不完全可信, 因此密钥分层可限制 eNB 泄露影响。

后向安全: 目标 eNB 不能解密源 eNB 下过去通信。前向安全: 源 eNB 不能知道目标 eNB 下未来通信密钥。LTE 通过 KDF、目标小区参数、 K_{eNB}^* 、NH/NCC 等机制增强切换密钥更新。结论要分场景: LTE 能较好增强后向安全, 并通过 NH/NCC 改善前向安全; 但不能说所有情况下绝对完全实现, 效果取决于切换方式、密钥派生和上下文转移方式。

必写关键词: NAS/AS; eNB 不完全可信; K_{ASME} ; K_{eNB} ; NH/NCC; 前向安全; 后向安全。

8-2 [B, 10 分] LTE 为什么要把 NAS 安全和 AS 安全分开?

考试答案要点:

NAS 安全保护 UE 与 MME 之间的核心网控制信令, AS 安全保护 UE 与 eNB 之间的 RRC 信令和用户面。LTE 中 eNB 功能增强、数量多、部署分散, 可能处于不完全可信环境。因此把 NAS 和 AS 分开, 可以实现安全边界清晰和密钥隔离: eNB 只掌握接入层密钥, 不掌握 NAS 密钥。即使某个 eNB 被攻破, 也不应直接破坏 UE 与核心网之间的 NAS 安全。

必写关键词: NAS; AS; MME; eNB; 密钥隔离; 不完全可信。

8-3 [B, 10 分] 说明 LTE 安全连接建立过程。

考试答案要点:

LTE 安全连接可按“认证-密钥派生-安全模式控制-数据保护”写: UE 与网络运行 EPS-AKA, 完成双向认证并产生 CK/IK; 由 CK/IK 派生 K_{ASME} , 再派生 NAS 加密/完整性密钥和 K_{eNB} ; MME 与 UE 建立 NAS 安全, 保护核心网控制信令; eNB 与 UE 建立 AS 安全, 派生 RRC 和用户面相关密钥; 通过 Security Mode Command/Complete 协商算法并开启完整性和加密保护。

必写关键词: EPS-AKA; K_{ASME} ; NAS 安全; AS 安全; Security Mode Command。

8-4 [B, 10 分] LTE 有哪些典型攻击面?

考试答案要点:

LTE 的典型攻击面包括:

1. **eNB 风险:** eNB 数量多、部署分散、不完全可信, 可能被物理或网络攻击。

2. **用户面完整性缺口**：LTE 用户面完整性通常可选或未启用，可能导致 DNS 欺骗、重定向、数据注入等。
 3. **认证前信令风险**：部分重定向、广播、寻呼、附着前信令保护不足，可能被用于跟踪、降级或 DoS。
 4. **身份隐私风险**：IMSI/GUTI/S-TMSI 机制不能完全防跟踪，临时身份失效时仍可能暴露。
 5. **切换安全风险**：切换中若直接转发旧密钥或安全上下文处理不当，会影响前向/后向安全。
- 改进方向包括 NAS/AS 分层、NH/NCC 切换密钥更新、用户面完整性、临时身份更新、反降级和异常检测。

必写关键词：eNB；UP 完整性；认证前信令；GUTI；切换；DoS。

8-5 [B, 10 分] 为什么 5G 要引入用户面完整性保护？

考试答案要点：

LTE 中 NAS 和 RRC 信令完整性通常强制保护，但用户面完整性通常可选或未启用。加密只能防窃听，不能防篡改。攻击者即使看不懂密文，也可能修改、插入、重放用户面数据，导致 DNS 欺骗、HTTP 重定向、数据注入等风险。

5G 支持并增强用户面完整性保护，可按业务和承载配置。高安全业务如工业控制、车联网、电网、医疗应开启 UP 完整性；普通大流量业务可根据性能开销选择。结论：5G 引入 UP 完整性是为了弥补“只加密不认证”的缺口。

必写关键词：UP 完整性；LTE 缺口；只加密不认证；高安全业务。

8 第 12 讲：5G 网络安全

12-1 [A, 15 分] 5G 匿名的新方法是什么？分析优缺点。

考试答案要点：

5G 使用 SUCI 隐藏 SUPI。SUPI 是用户永久身份，类似 IMSI；SUCI 是 UE/USIM 用归属网公钥对 SUPI 随机化加密后得到的隐藏身份。UE 在空口发送 SUCI，归属网 SIDF 用私钥恢复 SUPI。随机化很重要，同一 SUPI 每次应生成不同 SUCI，否则仍可能被链接跟踪。

优点：永久身份不再在空口明文暴露，缓解 IMSI catcher；随机化降低长期跟踪和可链接性；首次接入或无临时身份时也可隐藏永久身份；与 5G-AKA、AUSF/SEAF、分层密钥结合，增强认证和密钥隔离。

不足：不是完全匿名，寻呼、位置更新、业务模式、无线指纹、错误消息仍可能泄露关联；依赖归属网公钥配置、USIM 实现和随机数质量；服务网和归属网仍需合法识别用户，所以 SUCI 是对空口攻击者隐藏永久身份，不是对所有网络实体匿名。

必写关键词：SUPI；SUCI；归属网公钥；随机化；SIDF；IMSI catcher；可链接性。

12-2 [B, 10 分] 5G-AKA 相比 LTE AKA 有哪些增强？

考试答案要点：

5G-AKA 在 LTE AKA 基础上增强了身份隐私、归属网控制、服务网绑定和密钥层次。主要包括：使用 SUPI/SUCI 隐藏永久身份；引入 AUSF、SEAF 等功能实体；认证中绑定服务网身份，防止服务网冒充；归属网参与最终确认；密钥层次更清晰，如 K_{AUSF} 、 K_{SEAF} 、 K_{AMF} 、 K_{gNB} ；支持 5G-AKA、EAP-AKA' 等统一认证框架。

必写关键词：SUCI；AUSF；SEAF；服务网身份绑定；归属网确认；分层密钥。

12-3 [B, 10 分] 说明 SEPP 的作用。

考试答案要点：

SEPP 是 Security Edge Protection Proxy，用于保护 5G 漫游边界。5G 核心网采用 SBA 服务化架构，跨运营商漫游时会有服务化接口通信。SEPP 位于不同 PLMN 边界，负责跨运营商信令的完整性/机密性保护、消息过滤、拓扑隐藏、访问控制和安全审计。它的本质作用是保护运营商之间的网络域边界，防止漫游信令被篡改、滥用或泄露网络内部结构。

必写关键词：SEPP；漫游；PLMN；SBA；拓扑隐藏；消息过滤。

12-4 [B, 10 分] 5G 切片安全要解决什么问题？为什么需要二次认证？

考试答案要点：

5G 主认证只能证明 UE 是合法移动用户，但不能证明它有权访问某个行业切片。网络切片面向不同业务，如智能电网、工业控制、车联网、医疗等，不同切片有不同安全策略和访问权限。因此需要切片隔离、切片级访问控制和二次认证。二次认证用于验证用户是否有资格访问特定切片，实现最小权限，防止普通用户或被攻破终端越权进入高安全切片。

必写关键词：网络切片；行业业务；二次认证；访问控制；隔离；最小权限。

12-5 [B, 10 分] 5G SBA 服务化核心网需要解决哪些安全问题？

考试答案要点：

SBA 是 5G 服务化架构，核心网功能像 API 服务一样互相调用。它带来的安全问题包括：服务接口暴露增多，可能被未授权访问；API 调用可能越权；服务发现和注册可能被伪造；跨网元信令可能被篡改或重放；日志和审计不足会导致攻击难追踪。改进应包括 TLS 保护传输、OAuth/令牌机制做服务授权、网元身份认证、细粒度访问控制、服务发现安全、接口限流、日志审计和异常检测。总结：SBA 安全本质是把传统电信网元安全扩展到 API 安全和零信任访问控制。

必写关键词：SBA；API；TLS；OAuth；服务发现；访问控制；审计。

9 第 10 讲：课程总结与未来安全

10-1 [C, 10 分] 为什么 5G 不是简单加强空口加密？

考试答案要点：

因为 5G 的安全边界已经从单一空口扩展到身份隐私、接入认证、用户面完整性、网络切片、漫游边界、SBA 服务化核心网、边缘计算和垂直行业业务。只加强空口加密只能防窃听，不能解决 SUPI 暴露、切片越权、服务化接口滥用、漫游信令攻击、用户面篡改、边缘节点不可信等问题。5G 安全是多域协同：SUCI 保护身份，5G-AKA 增强认证，UP 完整性补用户面缺口，SEPP 保护漫游边界，切片二次认证保护行业切片，SBA 需要 TLS/OAuth/API 鉴权和审计。

10-2 [C, 10 分] 未来移动网络安全研究热点有哪些？

考试答案要点：

可从以下方向写：空天地一体化安全，卫星/无人机链路时延大、拓扑变化快；网络切片和零信任，不同业务共享基础设施但需强隔离；MEC/边缘计算安全，边缘节点更开放、易被攻击；海量物联网安全，终端能力弱、数量大、密钥管理困难；AI 辅助安全与 AI 自身安全，既可用于异常检测，也可能被投毒和对抗攻击；后量子密码，应对量子计算对传统公钥密码的威胁；形式化验证，用数学方法验证认证协议安全。

10-3 [A, 综合比较] 比较 GSM、WCDMA、LTE、5G 在认证、完整性、身份隐私和密钥管理上的演进。

考试答案要点：

GSM 主要提供用户鉴权、TMSI 临时身份和空口加密，但只有网络认证用户，缺少用户对网络认证，也缺少完整性保护。WCDMA 使用 AKA 实现双向认证，认证向量含 RAND、XRES、CK、IK、AUTN，CK/IK 分离，并增加信令完整性保护。LTE 使用 EPS-AKA，进一步区分 NAS/AS 安全，使用 GUTI/S-TMSI 隐藏身份，密钥从 K_{ASME} 派生到 NAS、eNB、RRC、UP，并用 NH/NCC 支持切换密钥更新，但用户面完整性通常可选。5G 使用 SUPI/SUCI 隐藏永久身份，5G-AKA/EAP 增强认证，密钥层次包括 K_{AUSF} 、 K_{SEAF} 、 K_{AMF} 、 K_{gNB} ，并增强用户面完整性、切片安全、SEPP 漫游安全和 SBA 接口安全。

总结趋势：单向认证到双向/增强认证；只加密到完整性保护；临时身份到公钥隐藏永久身份；简单密钥到分层密钥；单一空口安全到接入域、网络域、切片、服务化核心网多域协同。

必写关键词：GSM 单向；WCDMA AKA；LTE NAS/AS；5G SUCI；密钥分层；完整性增强。

10-4 [A, 20 分综合设计] 设计一个无线接入安全方案，要求保护永久身份、双向认证、协商会话密钥，并保护后续信令和用户数据。

考试答案要点：

可按“身份保护 → 双向认证 → 密钥协商 → 安全模式建立 → 数据保护 → 切换更新”写。

1. **身份保护**：终端不直接发送 IMSI/SUPI，优先使用 TMSI/GUTI；无临时身份时使用归属网公钥随机化加密永久身份，形成类似 SUCI 的隐藏身份。
2. **认证请求**：终端发送隐藏身份、支持算法、随机数和网络标识，防止身份暴露和降级。
3. **认证向量**：归属网根据长期密钥生成 RAND、XRES、AUTN、加密密钥材料和完整性密钥材料。
4. **双向认证**：UE 验证 AUTN 中 MAC 和 SQN，确认网络合法且消息新鲜；网络比较 RES/XRES，确认用户合法。
5. **密钥派生**：用 KDF 派生信令加密密钥、信令完整性密钥、用户面加密密钥、用户面完整性密钥，并区分方向、承载和算法。
6. **安全模式建立**：安全模式命令应完整性保护，明确选择的加密算法、完整性算法、计数器初值，防止算法协商被篡改。
7. **数据保护**：控制信令必须完整性保护并加密；用户面至少加密，高安全业务开启完整性。报文使用 COUNT/Seq、方向、承载号和 Nonce，并纳入 MAC/认证标签。
8. **切换更新**：切换时不直接复用旧基站密钥，应使用 KDF、目标小区参数和类似 NH/NCC 的链式派生，限制旧基站和新基站知道不该知道的密钥。

总结：完整无线接入安全不能只靠加密，而要同时覆盖身份隐私、双向认证、密钥协商、完整性、防重放和切换密钥更新。

必写关键词：SUCI/TMSI；AUTN；RAND；RES/XRES；KDF；完整性；COUNT；切换密钥。

综合分析题专项模板

这部分专门应对 15-20 分“给一个方案让你分析”的题。答题不要只评价算法，要围绕安全目标发散：机密性、完整性、认证、新鲜性、身份隐私、密钥管理、切换安全。

模板 1 [A, 通用分析] 某方案只加密用户面数据，不做完整性校验，也不检查序列号。请分析缺陷并改进。

考试答案要点：

该方案只能提供有限机密性，不能提供完整性和新鲜性。无线信道是开放信道，攻击者不能窃听，还能主动修改、插入、删除或重放密文分组。只加密可以让攻击者看不懂明文，但不能阻止他改密文；没有 MAC 或认证标签，接收方无法判断数据是否被篡改。不检查序列号、COUNT 或时间新鲜性，旧报文可能被重复发送并被接收端接受，形成重放攻击。若只保护用户面而忽略控制信令，承载建立、算法协商、切换等过程也可能被攻击。

改进时应启用用户面完整性保护，或使用 AES-GCM、AES-CCM 等认证加密算法；若继续使用普通加密模式，应采用“先加密后 MAC”。认证范围应覆盖双方身份、方向、承载号、算法标识、COUNT/序列号、IV/Nonce 和密文。接收端维护重放窗口，拒绝重复、过期和异常乱

序数据。同时用 KDF 分离加密密钥和完整性密钥，在切换、重认证或计数器接近上限时更新密钥。

必写关键词：只加密不够；完整性；新鲜性；COUNT；重放窗口；认证加密。

模板 2 [A，身份隐私] 某无线接入方案要求终端使用永久身份明文接入网络。请分析问题并改进。

考试答案要点：

该方案会造成用户身份隐私泄露。无线信道开放，攻击者可以被动监听 IMSI/SUPI 等永久身份，并把多次接入行为关联到同一用户，从而实现位置跟踪、用户画像和长期监控。若攻击者主动搭建伪基站，还可能诱导终端反复发送永久身份，使隐私风险更严重。永久身份一旦暴露，即使后续数据加密，也已经泄露了“是谁在接入”。

改进时应优先使用临时身份或隐藏身份。2G/3G/4G 中可使用 TMSI、P-TMSI、GUTI 等临时身份，并在安全保护开启后定期更新；5G 中可使用 SUCI，即用归属网公钥对 SUPI 做随机化加密，让空口不直接暴露永久身份。首次接入、寻呼、重同步和错误处理也要避免泄露永久身份，错误消息尽量统一，防止攻击者通过失败原因判断用户是否存在。

必写关键词：IMSI/SUPI；TMSI/GUTI/SUCI；随机化；伪基站；位置跟踪。

模板 3 [A，认证缺陷] 某方案只有网络认证用户，没有用户认证网络。请分析缺陷并改进。

考试答案要点：

该方案属于单向认证，只能证明用户是否合法，不能证明网络是否合法。攻击者可以伪装成合法基站或接入点，诱导终端接入，进一步获取永久身份、发起降级攻击、关闭加密、选择弱算法，或者转发和篡改信令。这也是 GSM 容易受到伪基站和 IMSI catcher 攻击的重要原因。

改进时应采用双向认证机制，使终端也能验证网络合法性。典型写法是 AKA：网络发送 RAND 和 AUTN，UE 用 USIM 中的长期密钥验证 AUTN 中的 MAC 和 SQN；MAC 正确说明认证令牌来自掌握长期密钥的归属网，SQN 合理说明消息不是旧认证向量重放。UE 再返回 RES，网络比较 RES/XRES 完成对用户的认证。服务网身份、算法协商结果和安全上下文也应纳入认证或密钥派生，防止中间人和降级攻击。

必写关键词：单向认证；伪基站；双向认证；AUTN；MAC；SQN；降级攻击。

模板 4 [A，密钥管理] 某方案长期使用同一通信密钥，且不同方向、不同业务共用同一密钥。请分析缺陷并改进。

考试答案要点：

长期使用同一密钥会扩大密钥泄露后的影响范围。一旦密钥泄露，攻击者可能解密长期历史通信或伪造后续通信。若同一密钥同时用于加密、完整性、上行、下行、信令和用户面，还会出现一钥多用问题，使不同安全功能互相影响。对流密码或计数器类模式来说，长期使用还可能导致密钥流、Nonce 或计数器复用，增加密码分析风险。

改进时应通过认证密钥协商生成新鲜会话密钥，并使用 KDF 派生不同用途的子密钥。可按层次写：长期密钥只用于认证和派生，不直接保护业务；会话密钥再派生出 NAS/AS 密钥、RRC/UP 密钥、加密密钥/完整性密钥，并区分上行和下行、不同承载和算法。密钥应在重新认证、切换、计数器接近上限、用户重新接入或安全策略触发时更新，减少旧密钥暴露带来的损失。

必写关键词：密钥新鲜；KDF；密钥分离；一钥多用；周期更新。

模板 5 [A，切换安全] 切换过程中，源基站直接把旧密钥交给目标基站使用。请分析对前向安全和后向安全的影响。

考试答案要点：

直接把旧密钥交给目标基站是不安全的。后向安全指目标基站不能解密源基站下已经发生的历史通信；若目标基站拿到源基站旧密钥，就可能解密过去通信，后向安全被破坏。前向安全指源基站不能知道目标基站未来通信所用密钥；如果目标基站继续使用源基站已知的旧密钥，源基站也可能解密未来通信，前向安全被破坏。

改进时不应直接复用旧基站密钥，而应使用密钥派生函数从上层密钥或 Next Hop 值派生目标基站密钥，并把目标小区、目标基站标识、计数器等参数纳入派生。LTE/5G 中可用类似 NH/NCC 的链式更新机制支持切换密钥更新：目标基站拿到的是新密钥，不能反推出历史密钥；源基站也不能推出目标基站未来密钥。必要时还应重新认证或刷新安全上下文。

必写关键词：前向安全；后向安全；旧密钥复用；KDF；NH/NCC；目标基站密钥。

最后十分钟速记

- 只加密不够：一定补完整性、认证、防重放、密钥分离。
- WEP：RC4、24 bit IV、CRC 不是 MAC、静态密钥、密钥流复用。
- GSM：单向认证、无完整性、IMSI 可能暴露、伪基站。
- WCDMA：AKA、AV、AUTN、SQN、CK/IK、双向认证、信令完整性。
- TETRA：空口加密是终端-网络；端到端加密是终端-终端；同步对象不同。
- LTE：eNB 不完全可信、NAS/AS 分层、 K_{ASME} 、 K_{eNB} 、NH/NCC、UP 完整性缺口。
- 5G：SUPI/SUCI、随机化、AUSF/SEAF、UP 完整性、SEPP、切片二次认证、SBA。